Нормативно-правове забезпечення кібербезпеки

Експерт Українського науково-дослідного інституту спеціальної техніки та судових експертиз СБУ
к.т.н. Пірог Олександр Вікторович

The Cybersecurity Act (2018)

Регламент (ЄС) 2019/881 про Агентство Європейського Союзу з кібербезпеки (European Union Agency for Cybersecurity) та про сертифікацію кібербезпеки інформаційно-комунікаційних технологій («Акт про кібербезпеку»).

- Створення Європейської агенції з мережевої та інформаційної безпеки (**ENISA**) потім Агентство Європейського Союзу з кібербезпеки (European Union Agency for Cybersecurity)

Основні завдання ENISA:

- підтримка впровадження політики та законодавства ЄС у сфері кібербезпеки;
- розвиток спроможностей: підтримка CSIRT-команд, проведення навчань;
- сприяння співпраці між зацікавленими сторонами, включно з CERT-EU;
- підтримка європейської системи сертифікації кібербезпеки ІКТ;
- збір та аналіз інформації про кіберзагрози, новітні технології й інциденти;
- підвищення обізнаності громадськості та просування культури кібербезпеки;
- консультування з питань досліджень і інновацій;
- сприяння міжнародній співпраці у сфері кібербезпеки.

Національна система кібербезпеки представляє собою комплексну систему взаємодії між:
- Державною службою спеціального зв’язку та захисту інформації України,
- Національною поліцією України,
- Службою безпеки України,
- Міністерством оборони України та Генеральним штабом Збройних Сил України,
- розвідувальними органами,
- Національним банком України.

(Стаття 8. Закону України «**Про основні засади забезпечення кібербезпеки України**»)

Провідним суб’єктом національної системи кібербезпеки є Державна служба спеціального зв’язку та захисту інформації України (ДССЗЗІ).

Захист персональних даних в Україні

Базовий закон - Закон України "Про захист персональних даних".

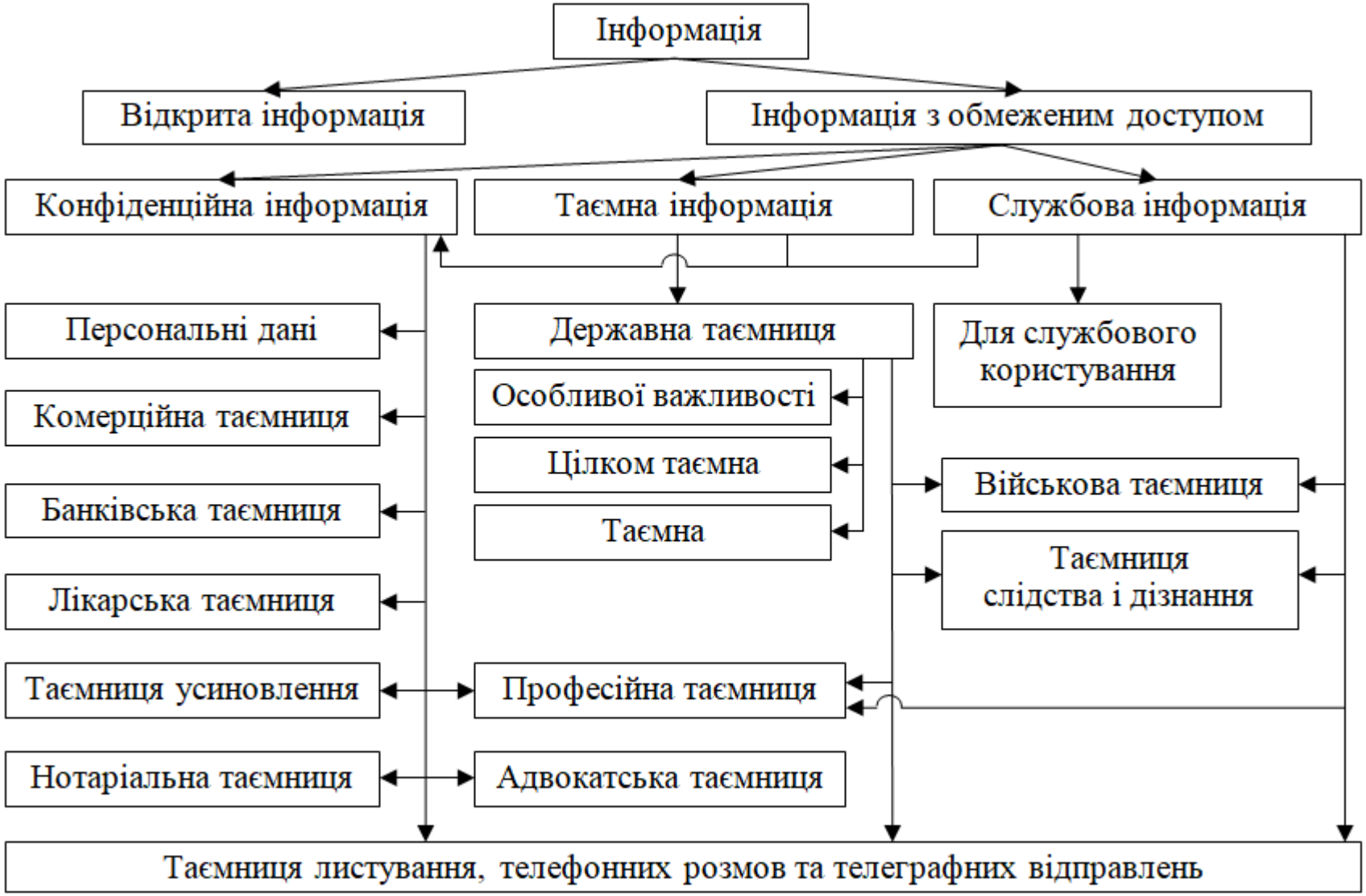
Закон України “Про інформацію ” ст. 11. Інформація про фізичну особу

1. **Інформація про фізичну особу (персональні дані)** - відомості чи сукупність відомостей про фізичну особу, яка ідентифікована або може бути конкретно ідентифікована.

2. Не допускаються збирання, зберігання, використання та поширення конфіденційної інформації про особу без її згоди, крім випадків, визначених законом, і лише в інтересах національної безпеки, економічного добробуту та захисту прав людини.

До конфіденційної інформації про фізичну особу належать, зокрема, дані про її
- національність,
- освіту,
- сімейний стан,
- релігійні переконання,
- стан здоров'я,
- а також адреса,
- дата і місце народження.

Кожному забезпечується вільний доступ до інформації, яка стосується його особисто, крім випадків, передбачених законом.



Види інформації

Відкритою інформацією є будь-які відомості про суб’єкт господарювання, що є у володінні, користуванні або розпорядженні суб’єкта та не віднесені до категорії інформації з обмеженим доступом.

Інформацією з обмеженим доступом – інформація, доступ до якої обмежено у відповідності з законом з метою захисту прав та законних інтересів її власників.

Правовий режим інформації з обмеженим доступом покликаний охороняти відомості, вільний обіг яких може порушити права й інтереси держави, суспільства, окремої особи, забезпечити інформаційну незалежність суб’єктів приватного права у відносинах із державою і особою, узгодити публічну потребу у свободі інформації та право кожного на збереження таємниці.

Санкціонований та несанкціонований доступ до інформації.

Несанкціонований – сукупність прийомів і порядок дій з метою одержання (добування) охоронюваних даних протиправним шляхом (таємне спостереження, перехоплення повідомлень, крадіжки зразків, документів тощо).

Легальну можливість володіти інформаційним ресурсом має лише його **власник** або особа, яка отримала у власника відповідний дозвіл.

Інформація з обмеженим доступом за своїм режимом **поділяється** на:
- конфіденційну (персональні дані, комерційна, медична, банківська, адвокатська…),
- таємну,
- службову (не таємна).

ч. 2 ст. 21 Закону України «Про інформацію»:
Конфіденційна інформація – певні відомості, які перебувають у володінні, користуванні або розпорядженні окремих фізичних або юридичних осіб.

Таємна інформація – інформацію, яка містить відомості, складові державну і іншу передбачену законом таємницю, розголошення якої заподіює збиток особі, суспільству і державі.

Закон України «Про державну таємницю» :

Державна таємниця (секретна інформація) – вид таємної інформації, що охоплює відомості у сфері оборони, економіки, науки і техніки, зовнішніх відносин, державної безпеки та охорони правопорядку, розголошення яких може завдати шкоди національній безпеці України та які визнані у порядку, встановленому цим Законом, державною таємницею і підлягають охороні державою.

Матеріальні носії секретної інформації – матеріальні об’єкти, в тому числі фізичні поля, в яких відомості, що становлять державну таємницю, відображені у вигляді текстів, символів, образів, сигналів, технічних рішень, процесів тощо.

Доступ до державної таємниці – надання повноважною посадовою особою дозволу громадянину на ознайомлення з конкретною секретною інформацією та провадження діяльності, пов’язаної з державною таємницею, або ознайомлення з конкретною секретною інформацією та провадження діяльності, пов’язаної з державною таємницею, цією посадовою особою відповідно до її службових повноважень.

Допуск до державної таємниці – оформлення права громадянина на доступ до секретної інформації.

Закон України «Про державну таємницю» :

Гриф секретності – реквізит матеріального носія секретної інформації, що засвідчує ступінь секретності даної інформації.

Засекречування матеріальних носіїв інформації – введення у встановленому законодавством порядку обмежень на поширення та доступ до конкретної секретної інформації шляхом надання відповідного грифа секретності документам, виробам або іншим матеріальним носіям цієї інформації.

Ступінь секретності (особливої важливості, цілком таємно, таємно) – категорія, яка характеризує важливість секретної інформації, ступінь обмеження доступу до неї та рівень її охорони державою.

Криптографічний захист секретної інформації – вид захисту, що реалізується шляхом перетворення інформації з використанням спеціальних даних (ключових даних) з метою приховування (або відновлення) змісту інформації, підтвердження її справжності, цілісності, авторства тощо.

Технічний захист секретної інформації – вид захисту, спрямований на забезпечення інженерно-технічними заходами конфіденційності, цілісності та унеможливлення блокування інформації.

Сфери розповсюдження державної таємниці на інформацію:

У сфері оборони до держаної таємниці відноситься інформація:

- про зміст стратегічних і оперативних планів, документів бойового управління, підготовку та проведення військових операцій, стратегічне та мобілізаційне розгортання військ, а також про інші найважливіші показники, які характеризують організацію, чисельність, дислокацію, бойову і мобілізаційну готовність, бойову та іншу військову підготовку, озброєння та матеріально-технічне забезпечення Збройних Сил України та інших військових формувань;
- про напрями розвитку окремих видів озброєння, військової і спеціальної техніки, їх кількість, тактико-технічні характеристики, організацію і технологію виробництва, наукові, науково-дослідні та дослідно-конструкторські роботи, пов’язані з розробленням нових зразків озброєння, військової і спеціальної техніки або їх модернізацією, а також про інші роботи, що плануються або здійснюються в інтересах оборони країни;
- про сили і засоби Цивільної оборони України, можливості населених пунктів, регіонів і окремих об’єктів для захисту, евакуації і розосередження населення, забезпечення його життєдіяльності та виробничої діяльності об’єктів народного господарства у воєнний час або в умовах надзвичайних ситуацій;
- про геодезичні, гравіметричні, картографічні та гідрометеорологічні дані і характеристики, які мають значення для оборони країни.

Сфери розповсюдження державної таємниці на інформацію:

У сфері економіки, науки і техніки таємною є інформація:

- про мобілізаційні плани і мобілізаційні потужності господарства України, запаси та обсяги постачання стратегічних видів сировини і матеріалів, а також зведені відомості про номенклатуру та рівні накопичення, про загальні обсяги поставок, відпуску, закладення, розміщення і фактичні запаси державного резерву;
- про використання транспорту, зв'язку, потужностей інших галузей та об'єктів інфраструктури держави в інтересах забезпечення її безпеки;

про плани, зміст, обсяг, фінансування та виконання державного замовлення для забезпечення потреб оборони та безпеки;

про плани, обсяги та інші найважливіші характеристики добування, виробництва та реалізації окремих стратегічних видів сировини і продукції;

- про державні запаси дорогоцінних металів монетарної групи, коштовного каміння, валюти та інших цінностей, операції, пов'язані з виготовленням грошових знаків і цінних паперів, їх зберіганням, охороною і захистом від підроблення, обігом, обміном або вилученням з обігу, а також про інші особливі заходи фінансової діяльності держави;
- про наукові, науково-дослідні, дослідно-конструкторські та проектні роботи, на базі яких можуть бути створені прогресивні технології, нові види виробництва, продукції та технологічних процесів, що мають важливе оборонне чи економічне значення або суттєво впливають на зовнішньоекономічну діяльність та національну безпеку України.

Сфери розповсюдження державної таємниці на інформацію:

У сфері зовнішніх відносин до таємної відноситься інформація:

- про директиви, плани, вказівки делегаціям і посадовим особам з питань зовнішньополітичної і зовнішньоекономічної діяльності України, спрямовані на забезпечення її національних інтересів і безпеки;
- про військове, науково-технічне та інше співробітництво України з іноземними державами, якщо розголошення відомостей про це завдаватиме шкоди національній безпеці України;
- про експорт та імпорт озброєння, військової і спеціальної техніки, окремих стратегічних видів сировини і продукції.

Сфери розповсюдження державної таємниці на інформацію:

У сфері державної безпеки та охорони правопорядку до таємної відноситься інформація:

- про особовий склад органів, що здійснюють оперативно-розшукову діяльність;
- про засоби, зміст, плани, організацію, фінансування та матеріально-технічне забезпечення, форми, методи і результати оперативно-розшукової діяльності, про осіб, які співпрацюють на конфіденційній основі;
- про організацію та порядок здійснення охорони адміністративних будинків та інших державних об’єктів, посадових;
- про систему урядового та спеціального зв’язку;
- про організацію, зміст, стан і плани розвитку криптографічного захисту секретної інформації, зміст і результати наукових досліджень у сфері криптографії, про системи та засоби криптографічного захисту секретної інформації, про державні шифри;
- про організацію режиму секретності в органах державної влади, органах місцевого самоврядування, на підприємствах, в установах і організаціях, державні програми, плани та інші заходи у сфері охорони державної таємниці;
- про організацію, зміст, стан і плани розвитку технічного захисту секретної інформації;
- про результати перевірок нагляду за додержанням законів, та про зміст матеріалів дізнання, досудового слідства та судочинства з питань охорони інформації, що відноситься до державної таємниці;
- про інші засоби, форми і методи охорони держаної таємниці.

Забороняється віднесення до державної таємниці будь-яких відомостей, якщо цим будуть звужуватися конституційні права та свободи людини і громадянина, завдаватиметься шкода здоров’ю та безпеці населення.

Не відноситься до державної таємниці інформація:

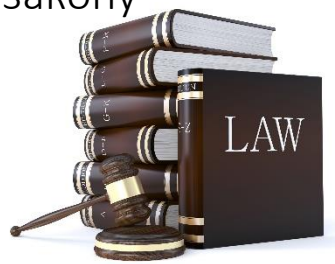
- про стан довкілля, про якість харчових продуктів і предметів побуту;
- про аварії, катастрофи, небезпечні природні явища та інші надзвичайні події, які сталися або можуть статися і загрожують безпеці громадян;
- про стан здоров’я населення, його життєвий рівень, включаючи харчування, одяг, житло, медичне обслуговування та соціальне забезпечення, а також про соціально-демографічні показники, стан правопорядку, освіти і культури населення;
- про факти порушень прав і свобод людини і громадянина;
- про незаконні дії органів державної влади, органів місцевого самоврядування та їх посадових осіб;
- інша інформація, яка відповідно до законів та міжнародних договорів, згода на обов’язковість яких надана Верховною Радою України, не може бути засекречена.

Конфіденційною є інформація про фізичну особу, а також інформація, доступ до якої обмежено фізичною або юридичною особою, крім суб’єктів владних повноважень.

Конфіденційна інформація може поширюватися за бажанням (згодою) відповідної особи у визначеному нею порядку відповідно до передбачених нею умов, а також в інших випадках, визначених законом.
(**ст. 21 Закону «Про інформацію»**).
Громадяни і юридичні особи самостійно відносять до конфіденційної:
- інформацію професійного, ділового, виробничого, банківського, комерційного і іншого характеру;
- інформацію, яка є предметом їх професійного, ділового, виробничого, банківського, комерційного і іншого інтересу.

Якщо підприємство використовує інформацію, яка належить державі, доступ до такої інформації може бути обмежений шляхом поширення на неї статусу конфіденційної інформації (Для службового користування).

Не може бути віднесена до конфіденційної інформація
(ст. 21 Закону «Про інформацію»):
- про стан довкілля, якість харчових продуктів і предметів побуту;
- про аварії, катастрофи, небезпечні природні явища і інші надзвичайні події, які сталися або можуть статися і погрожують безпеці громадян;
- про стан здоров'я населення, його життєвий рівень, житло, медичне обслуговування і соціальне забезпечення, а також про соціально-демографічні показники, стан правопорядку, освіти і культури населення;
- про факти порушення прав і свобод людини, включаючи інформацію, що міститься в архівних документах колишніх радянських органів державної безпеки, пов'язаних з політичними репресіями, Голодомором 1932-1933 років в Україні та іншими злочинами, вчиненими представниками комуністичного та/або націонал-соціалістичного (нацистського) тоталітарних режимів;
- про незаконні дії органів державної влади, органів місцевого самоврядування, їх посадових та службових осіб;
- щодо діяльності державних та комунальних унітарних підприємств, господарських товариств, у статутному капіталі яких більше 50 відсотків акцій (часток) належать державі або територіальній громаді, а також господарських товариств, 50 і більше відсотків акцій (часток) яких належать господарському товариству, частка держави або територіальної громади в якому становить 100 відсотків, що підлягають обов'язковому оприлюдненню відповідно до закону
- інша інформація, доступ до якої відповідно до законів України і міжнародних договорів, згода на обов'язковість яких надана Верховною Радою України.



Службова інформація:
1. Інформація про діяльність суб’єкта господарювання, доступ до якої обмежено законом в цілях захисту його інтересів.
2. Інформація, що підлягає охороні, яка стала відома через виконання службових обов’язків посадовим особам суб’єкта: комерційна банківська таємниця, професійна таємниця, а також конфіденційна інформація про приватне життя особи.

Суб’єкти ІАД:
- фізичні (аналітики) і юридичних особи (аналітичні центри),
- об’єднання громадян (творчі, наукові, замовники),
- суб’єкти владних повноважень.
(Ст. 4 Закону України «Про інформацію»).
- вчені,
- наукових працівники,
- науково-педагогічних працівники,
- наукові установи,
- наукові організації,
- вищі навчальні заклади,
- громадські наукові організації.
(Ст. 4 Закону України «Про наукову і науково-технічну діяльність»)
- державні органи,
- органи місцевого та регіонального самоврядування
- юридичні особи та громадяни України,
- міжнародні організації,
- іноземні юридичні особи і громадяни
- особи без громадянства.
(Ст. 3 Закону України «Про науково-технічну інформацію»).

Об'єкти ІАД:
- інформація.
(П.2 ст. 4 Закону України «Про інформацію»)
- вітчизняна і зарубіжна науково-технічна інформація.
(Ст. 2 Закону України «Про науково-технічну інформацію»).

Суб’єкти національної системи захисту критичної інфраструктури:

1) Кабінет Міністрів України;
2) Апарат Ради національної безпеки і оборони України;
3) Центральна виборча комісія;
4) Національний банк України;
5) Національна комісія з цінних паперів та фондового ринку, Національна комісія, що здійснює державне регулювання у сфері зв’язку та інформатизації, Національна комісія, що здійснює державне регулювання у сферах енергетики та комунальних послуг;
6) Адміністрація Державної служби спеціального зв’язку та захисту інформації України;
7) Фонд державного майна України, інші центральні органи виконавчої влади із спеціальним статусом;
8) уповноважений орган у сфері захисту критичної інфраструктури України;
9) центральний орган виконавчої влади, який забезпечує формування та реалізує державну політику у сфері цивільного захисту;
10) секторальні та функціональні органи, інші міністерства та центральні органи виконавчої влади;
11) Служба безпеки України;
12) правоохоронні та розвідувальні органи, суб’єкти оперативно-розшукової та контррозвідувальної діяльності;
13) Збройні Сили України, інші військові формування, утворені відповідно до законів України;
14) місцеві органи виконавчої влади (військово-цивільні адміністрації - у разі утворення);
15) органи місцевого самоврядування;
16) оператори критичної інфраструктури;
17) підприємства, установи та організації незалежно від форми власності, які провадять діяльність, пов’язану із забезпеченням безпеки та стійкості критичної інфраструктури.

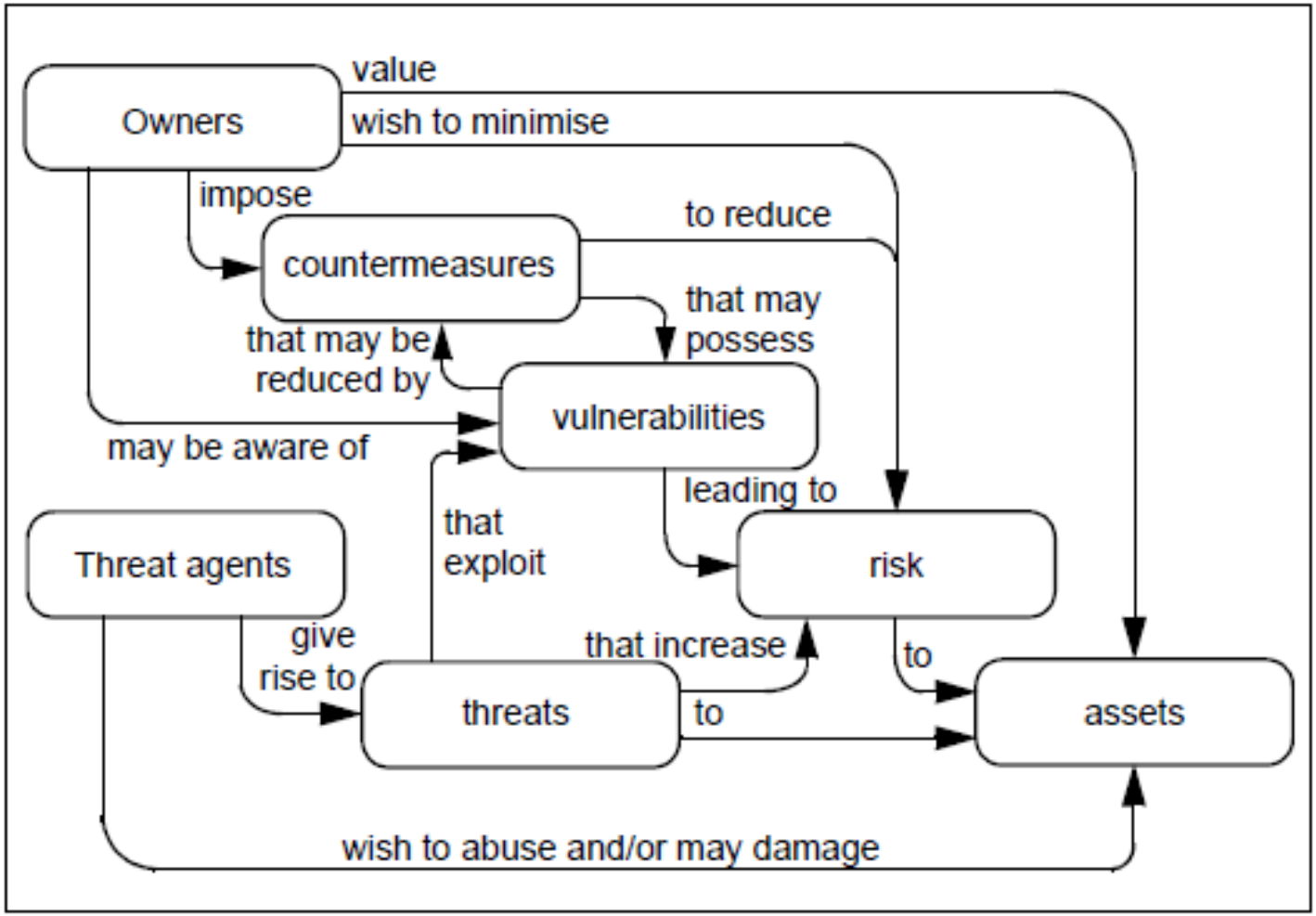
Загальні вимоги до кіберзахисту об’єктів критичної інфраструктури (ОКІ)
(Постанова КМУ)
- Організаційні та технічні заходи з кіберзахисту:
    - політика інформаційної безпеки;
    - управління доступом;
    - ідентифікація та автентифікація;
    - мережевий захист;
    - доступність та відмовостійкість;
    - визначення умов використання
        - змінних пристроїв та носіїв інформації;
        - ПЗ, АЗ;
    - визначення умов розміщення компонентів.

Базові вимоги до кіберзахисту ОКІ
- ОКІ повинен мати підрозділ або посаду з інформаційної безпеки;
- визначені права та обов’язки всіх категорій користувачів;
- перелік інформаційних, програмних та апаратних ресурсів;
- політика управління ризиками ІБ, методику їх оцінювання та оброблення (ISO 27005);
- не рідше одного разу на рік - обстеження ОКІ;
- документація на КСЗІ (систему інформаційної безпеки);
- ***політика ІБ***.

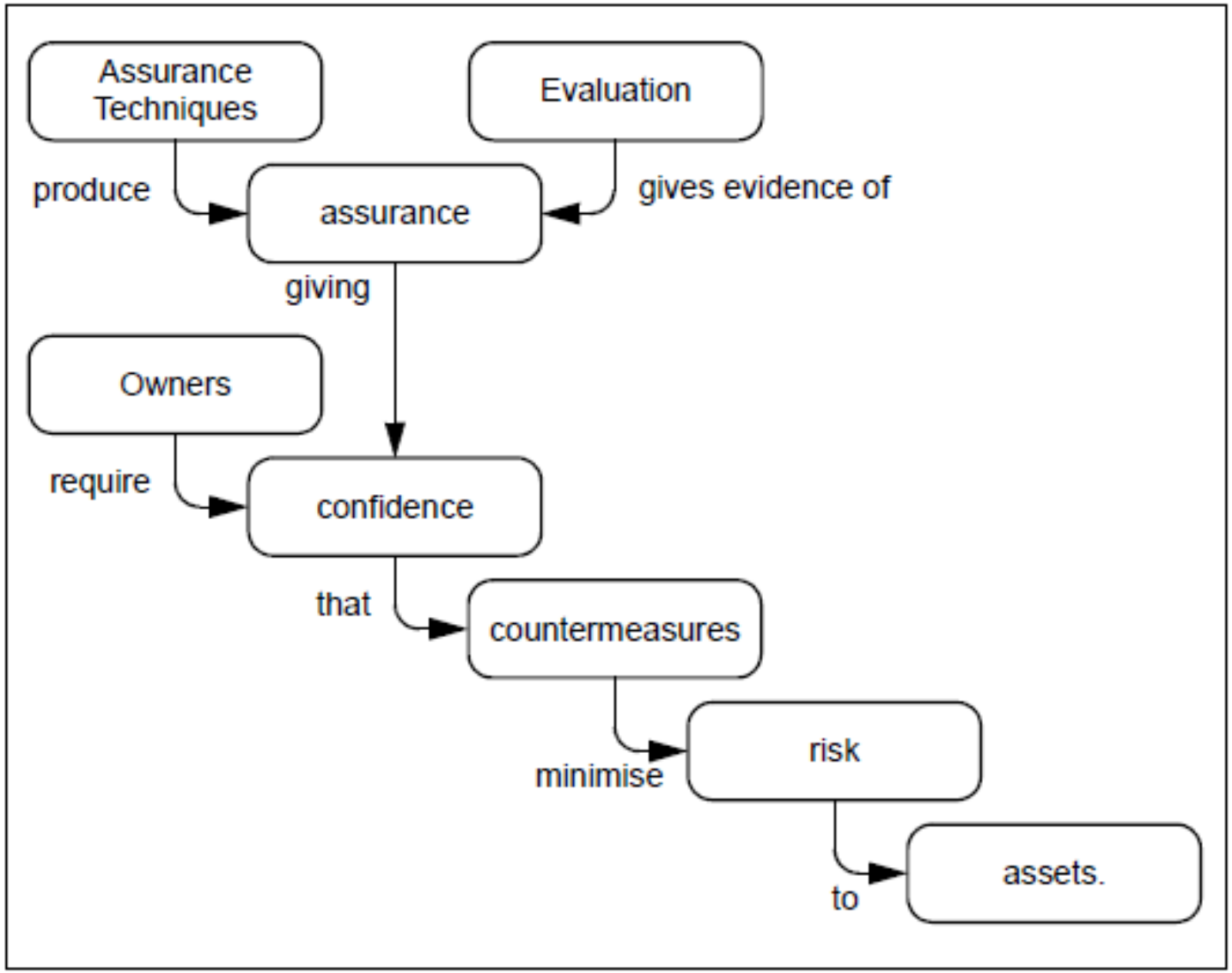
Політика ІБ

- мета, принципи,
- критичні бізнес/операційні процеси,
- порядку визначення, надання, зміни та скасування прав доступу
    - багатофакторна автентифікація,
    - паролі за замовчуванням,
    - IP, MAC,
- фізична безпека,
- взаємодія з постачальниками,
- управління обліковими записами, атрибутами,
- безперебійність
    - безперебійне живлення,
    - резервування, дублювання (кластеризація), балансування,
- порядок дій у випадках відмов,
- використання змінних (зовнішніх) пристроїв та носіїв,
- мережевий захист
    - фільтрація/моніторинг трафіку,
    - DMZ, APP, DB, Test .
- оновлення,
- реєстрація та аудит подій,
- управління інцидентами кібербезпеки,
- використання електронної пошти.

ISO 15408-1 Information technology - Security techniques - Evaluation criteria for IT security - Part 1: Introduction and general model
Інформаційні технології - Методи безпеки – Критерії оцінки IT-безпеки - Частина 1: Вступ і загальна модель



Концепція безпеки



Концепція оцінки

Security requirements

Functional specification

High-level design

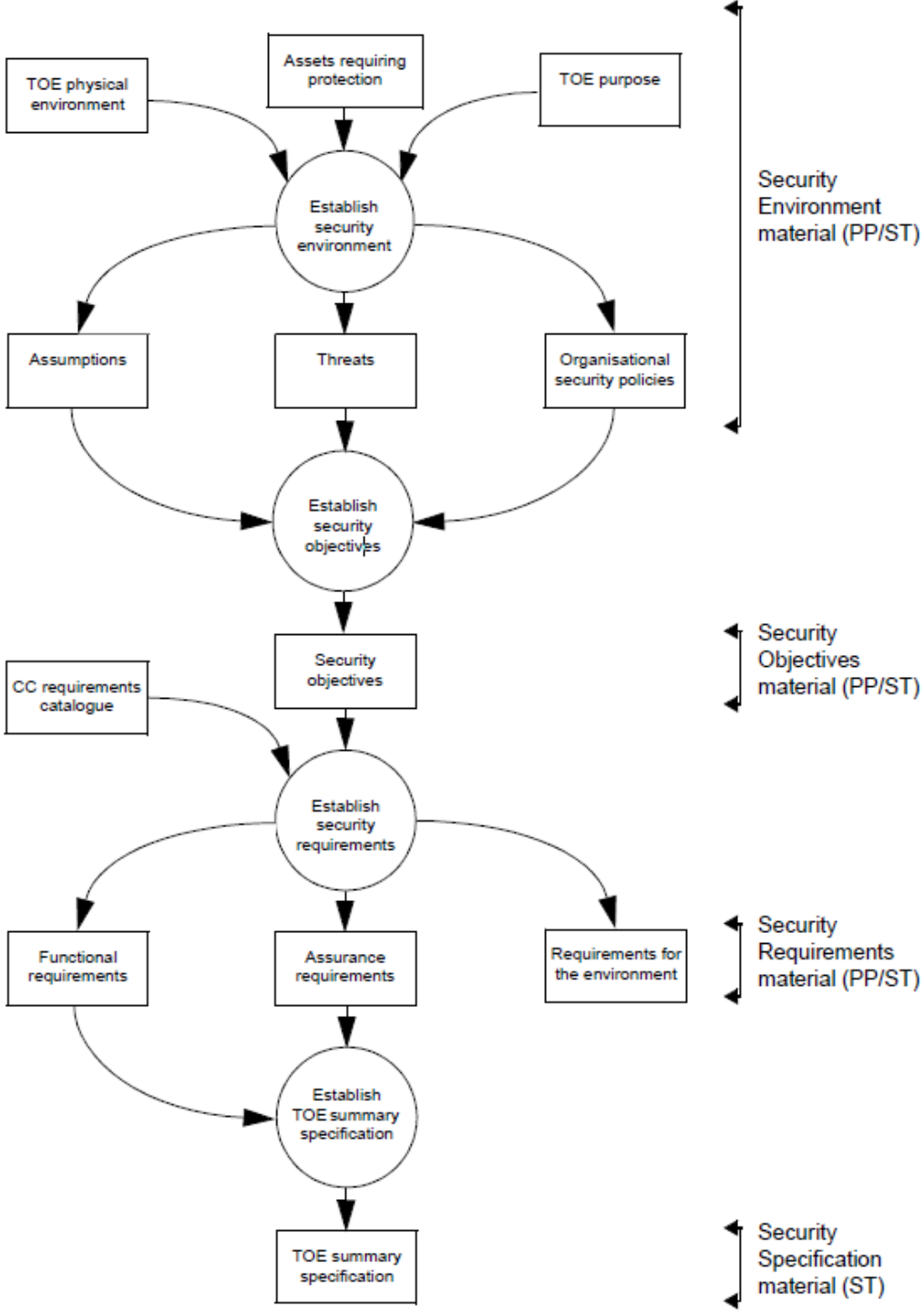
Source code/ Hardware drawings

Implementation

Design and implementation refinement

Correspondence analysis and integration testing

Модель розробки об'єкту оцінки



Одержання вимог та специфікацій

ISO 17799 Information technology - Security techniques –
Code of practice for information security management
Інформаційні технології - Методи безпеки -
Практичні правила менеджменту інформаційної безпеки

Варіанти обробки ризиків:
- Уникнути (Avoid).
- Знизити, пом'якшити (Mitigations).
- Передати (Transfer).
- Прийняти (Accept).

СЕРІЯ СТАНДАРТІВ ISO/IEC 27000

- ISO/IEC 27000 Огляд СУІБ, а також терміни та визначення.
- ISO/IEC 27001 Вимоги до СУІБ.
- ISO/IEC 27002 Засоби контролю ІБ.
- ISO/IEC 27003 Керівництво щодо впровадження СУІБ.
- ISO/IEC 27005 Керівництво з управління ризиками інформаційної безпеки.

Секторальні стандарти:
- ISO/IEC 27011 Телекомунікаційні послуги;
- ISO/IEC 27019 Енергетика;
- ISO/IEC 27701 Конфіденційна інформація та персональні дані…

Перший в 2005, останній в 2022.

ISO 27000 Information technology - Security techniques –
Information security management systems - Overview and vocabulary
Інформаційні технології - Методи безпеки -
Системи менеджменту інформаційної безпеки -
Загальний огляд і термінологія

Цей стандарт містить:
- огляд сімейства стандартів;
- введення в систему менеджменту інформаційної безпеки (СМІБ);
- короткий опис процесу
  "План (Plan) - Здійснення (Do) - Перевірка (Check) - Дія (Act)" (PDCA);
- терміни та визначення для використання в стандартах СМІБ.

Цей стандарт може бути застосований до всіх типів організацій:
- комерційні,
- некомерційні,
- урядові.

Визначення:

Інформаційна безпека (information security) – Збереження конфіденційності, цілісності і доступності інформації.
Конфіденційність (confidentiality) - Властивість інформації бути недоступною або закритою для неавторизованих осіб, сутностей або процесів.
Цілісність (integrity) – Властивість збереження правильності і повноти активів.
Доступність (availability) - Властивість бути доступним і готовим до використання за запитом авторизованого суб'єкта.
Контроль доступу (access control) - Забезпечення того, щоб доступ до активів був санкціонований і обмежується відповідно до вимог комерційної таємниці і безпеки.
Аутентифікація (authentication) - Забезпечення гарантії того, що заявлені характеристики об'єкта правильні.
Автентичність (authenticity) - Властивість, що гарантує, що суб'єкт або ресурс ідентичний заявленому.
Забезпечення безперервності бізнесу (business continuity) – Процеси і (або) процедури, що забезпечують впевненість в безперервності операцій бізнесу.

Актив (asset) - Що-небудь, що має цінність для організації.
Є різні типи активів:
- інформація;
- програмне забезпечення;
- матеріальні активи, наприклад комп'ютер;
- послуги;
- люди і їх кваліфікація, навички та досвід;
- нематеріальні активи, такі як репутація та імідж.

Подія (event) - Виникнення специфічного набору обставин.
Інцидент інформаційної безпеки (information security incident) - Одне або декілька небажаних або несподіваних подій інформаційної безпеки, які зі значним ступенем вірогідності призводять до компрометації операцій бізнесу і створюють загрози для інформаційної безпеки.
Атака (attack) - спроба знищення, розкриття, зміни, блокування, крадіжки, отримання несанкціонованого доступу до активу або його несанкціонованого використання.
Загроза (threat) - Можлива причина небажаного інциденту, який може завдати шкоди системі або організації.
Менеджмент інциденту інформаційної безпеки (information security incident management) - Процеси виявлення, інформування, оцінки, реагування, розгляду і вивчення інцидентів інформаційної безпеки.

Вразливість (vulnerability) - Слабке місце активу або заходів і засобів контролю і управління, яке може бути використане загрозою.
Ризик (risk) - Поєднання ймовірності події та її наслідків.
Ризик інформаційної безпеки (information security risk) - Потенційна можливість того, що вразливість буде використовуватися для створення загрози активу або групі активів, що призводить до збитків для організації.
Менеджмент ризику (risk management) - Скоординовані дії з управління організацією стосовно ризику.
Політика (policy) - Загальний намір і напрямок, офіційно висловлений керівництвом.
Результативність (effectiveness) - Ступінь реалізації запланованої діяльності та досягнення запланованих результатів.
Ефективність (efficiency) - Зв'язок між досягнутим результатом і тим, наскільки доцільно використані ресурси.

Заходи по впровадженню, контролю, підтримці і поліпшенню СМІБ:
a) визначення інформаційних активів і пов'язаних з ними вимог безпеки;
b) оцінка ризиків ІБ;
c) вибір і реалізація відповідних засобів управління для управління неприйнятними ризиками;
d) контроль, підтримка і підвищення ефективності засобів управління безпекою, пов'язаних з інформаційними активами організації.

ISO 27001 "Information technology - Security techniques – Information security management systems - Requirements
Інформаційні технології - Методи безпеки – Системи менеджменту інформаційної безпеки

- Вимоги КОНТЕКСТ ОРГАНІЗАЦІЇ
- РОЗУМІННЯ ОРГАНІЗАЦІЯ ТА ЇЇ КОНТЕКСТ

Визначення зовнішніх та внутрішніх проблем, які мають відношення до мети організації та впливають на її здатність досягти запланованого результату СУІБ.

Зовнішні проблеми - поза контролем організації (наприклад, політичні, правові, технологічні, соціальні, культурні, конкурентні чи природні фактори тощо).

Внутрішні питання – під контролем організації (наприклад, ресурси, знання, договірні відносини, цілі тощо).

- ПОТРЕБИ ТА ОЧІКУВАННЯ ЗАЦІКАВЛЕНИХ СТОРОН
    - Зацікавлені сторони, які стосуються СУІБ.
    - Вимоги зацікавлених сторін.
    - Які вимоги будуть вирішені через СУІБ.
- СФЕРА ЗАСТОСУВАННЯ СУІБ

    Межі та сфера застосування СУІБ.
- СИСТЕМИ УПРАВЛІННЯ ІНФОРМАЦІЙНОЮ БЕЗПЕКОЮ
    - Інтеграція СУІБ у процеси та бізнес-діяльність організації.
    - Постійне вдосконалення СУІБ.

КЕРІВНИЦТВО

- Встановлено політику та цілі ІБ.
- СУІБ інтегрована в процеси організації.
- Забезпечені необхідні ресурси для СУІБ.
- Повідомлено про необхідність ІБ.
- СУІБ досягає запланованих результатів.
- Сприяння постійному вдосконаленню.
- Підтримка людей зробити внесок у СУІБ.
- Підтримка менеджерів, щоб продемонструвати їхнє лідерство.

ПОЛІТИКА ІНФОРМАЦІЙНОЇ БЕЗПЕКИ

Вище керівництво має встановити політику ІБ, що:

- Відповідає меті організації.
- Включає цілі ІБ або надає структуру для встановлення цих цілей.
- Включає зобов’язання задовольняти відповідні вимоги та постійне вдосконалення.

РОЛЬ, ОБОВ'ЯЗКИ, ПОВНОВАЖЕННЯ

Найвище керівництво має гарантувати, що відповідальність і повноваження для ролей, пов’язаних з ІБ, розподілені та доведені.

Планування:

Визначення ризиків та можливостей та планування дій для їх усунення.

Оцінка ризику ІБ:

Ризик - вплив невизначеності на цілі.

Ризики ІБ – пов’язані з можливістю того, що загрози скористаються вразливими місцями інформаційного активу та завдадуть шкоди організації.

РИЗИК = Наслідки х Ймовірність

Критерії прийняття ризику та виконання оцінки ризику.

Ймовірність	Наслідки				
	Катастрофічна	Критичний	Серйозно	Значний	незначний
Майже напевно	Дуже високий	Дуже високий	Високий	Високий	Середній
Дуже ймовірно	Дуже високий	Високий	Високий	Середній	Середній
Ймовірно	Високий	Високий	Середній	Середній	Середній
Навряд чи	Середній	Середній	Середній	Середній	Низький
Малоймовірно	Середній	Середній	Середній	Низький	Низький

ЗАГРОЗИ ТА ВРАЗЛИВІ МІСЦЯ

Категорія загроз	Опис загроз
Фізичні	Вогонь, вода, забруднення, випромінювання.
Природні	Кліматичні, сейсмічні.
Інфраструктура	Системи живлення, охолодження, вентиляції.
Технічні збої	Пристрою, системи, порушення ремонтопридатності.
Дії людей	Теракт, диверсія, перехоплення випромінювання приладу, дистанційне шпигунство, підслуховування, крадіжка носіїв інформації або документів.
Компрометація послуг	Зловживання, підробка прав або дозволів, відмова від дій.
Організаційні	Відсутність персоналу, брак ресурсів, відмова постачальників послуг, порушення законів, норм

Категорія вразливостей	Опис вразливостей
Обладнання	Обслуговування носіїв даних, заміни обладнання, вологість, пил, забруднення.
Мережа	Недостатні механізми для підтвердження надсилання або отримання повідомлення, незахищені лінії зв'язку, чутливий трафік.
Персонал	Відсутність персоналу, неадекватні процедури найму, недостатня підготовка з безпеки.
Місця	Контроль фізичного доступу до будівель, приміщень, дверей та вікон, зони схильні до затоплень, нестабільна електромережа.
Організаційні	Процедура реєстрації користувачів та її скасування, перегляд прав доступу, положення про безпеку в договорах із клієнтами та третіми сторонами.

ВЛАСНИКІ РИЗИКУ

Визначення власників ризиків (осіб або організацій, які мають підзвітність і повноваження з управління ризиками)

АНАЛІЗ ТА ОЦІНКА РИЗИКУ

- Оцінка можливих наслідків та реалістичної ймовірністі виявлених ризиків, щоб визначити рівень ризику.
- Порівняння результатів аналізу ризику з критеріями прийнятності.

ОБРОБЛЕННЯ РИЗИКІВ ІБ

- Опції оброблення.
- Засоби контролю.
- План обробки.
- Схвалення власників ризиків щодо плану та прийняття залишкових ризиків.

ОПЦІЇ ОБРОБЛЕННЯ РИЗИКІВ

- Уникнення.
- Зниження.
- Передача.
- Прийняття.

ПОЛОЖЕННЯ ЩОДО ЗАСТОСОВНОСТІ (STATEMENT OF APPLICABILITY, SoA)
- Необхідні засоби контролю (обґрунтування включення, статус реалізації);
- Обґрунтування для виключень заходів безпеки, наданих у додатку А.

ПЛАН ОБРОБЛЕННЯ РИЗИКІВ
- Для кожного ризику ІБ:
- Дії щодо оброблення.

Стан виконання.
- Відповідальний, ресурси, часові рамки.

Залишковий ризик - ризик, який залишається після оброблення (приймається власником ризику).

ЦІЛІ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ
- Відповідають до політики.
- Вимірювані (якщо можливо).
- Враховуйте діючі вимоги.
- Відстежуються, повідомляються та оновлюються (за необхідності).

ПЛАН ДОСЯГНЕННЯ ЦІЛЕЙ ІБ
- Що буде зроблено?
- Хто відповідатиме?
- Які ресурси необхідні?
- Коли кожна ціль буде виконана?
- Як будуть оцінюватися результати?

ПІДТРИМКА

- РЕСУРСИ

Визначити та забезпечити ресурси, необхідні для створення, впровадження, підтримки та постійного вдосконалення СУІБ.

- КОМПЕТЕНТНІСТЬ
  - Визначити вимоги.
  - Забезпечити компетентність (освіта, навчання, досвід).
  - Діяти, щоб покращити або зберегти компетентність.
  - Оцінити ефективність дій.
- ОБІЗНАНІСТЬ персоналу про:
  - політика ІБ.
  - його вклад у СУІБ та переваги покращення результативності ІБ
  - наслідки невідповідності вимогам.
- КОМУНІКАЦІЯ
  - Визначити потребу у внутрішніх і зовнішніх комунікаціях.
  - З яких питань, коли, з ким, хто, як.
- КОНТРОЛЬ ДЛЯ ДОКУМЕНТОВАНОЇ ІНФОРМАЦІЇ
  - Розподіл, доступ, пошук.
  - Збереження та консервування.
  - Контроль версій.
  - Утримування й розташування.

ФУНКЦІОНУВАННЯ

- РОБОЧЕ ПЛАНУВАННЯ Й КОНТРОЛЬ
  - Планування, впровадження й контроль процесів, необхідних для виконання вимог ІБ.
  - Контроль змін.
  - Контроль зовнішніх процесів, продуктів або послуг.
- ОЦІНЮВАННЯ РИЗИКІВ ІБ

Через заплановані інтервали (можливо, раз на рік), а також у разі значних змін.

- ОБРОБЛЕННЯ РИЗИКІВ ІБ

План оброблення ризиків.

ОЦІНЮВАННЯ РЕЗУЛЬТАТИВНОСТІ

- МОНІТОРИНГ, ВИМІРЮВАННЯ, АНАЛІЗ ТА ОЦІНЮВАННЯ
  - що необхідно контролювати та вимірювати;
  - методи;
  - коли проводити моніторинг і вимірювання;
  - обов'язки (хто);
  - коли результати аналізуються та оцінюються.
- ВНУТРІШНІЙ АУДИТ
  - через заплановані проміжки часу;
  - програма внутрішнього аудиту.
- ПЕРЕГЛЯД З БОКУ КЕРІВНИЦТВА
  - Статус дій з попередніх перевірок.
  - Зміни в контексті організації (внутрішні/зовнішні).
  - Відгуки про показники ІБ.
  - Відгуки зацікавлених сторін.
  - Результати оцінки ризиків та план оброблення ризиків.
  - Можливості для вдосконалення.

ВДОСКОНАЛЕННЯ

НЕВІДПОВІДНОСТІ Й КОРЕГУВАЛЬНІ ДІЇ

Невідповідність – невиконання вимоги.

- Реагувати.
  Виправляти та контролювати ситуацію, вживати заходів щодо наслідків.
- Дослідити.
  Оцінити потребу в коригувальних діях.
- Визначте причину.
  Запропонуйте коригувальні дії.
- Оцінити.
  Оцінити ефективність коригувальних дій.

Додаток А ISO/IEC 27001:2022

34 засоби контролю ІБ розбито на 4 теми (або категорії):

- Організаційний контроль.
- Безпека людських ресурсів.
- Фізичний контроль.
- Технологічний контроль.

ОРГАНІЗАЦІЙНИЙ КОНТРОЛЬ

- Політики ІБ.
- Ролі та обов'язки з ІБ.
- Розподіл обов’язків.
- Обов'язки керівництва.
- Контакти з повноважними органами (законодавство, інциденти).
- Контакти з групами фахівців з певної проблематики.
- Розвідка загроз.
- ІБ в управлінні проектами (інтеграція ІБ в управління).
- Інвентаризація інформації та інших активів (ресурсів).
- Припустиме використання активів (ресурсів).
- Повернення активів (ресурсів).
- Класифікація інформації.
- Маркування інформації.
- Передавання інформації (всередині, між організаціями, усна інф., паперові, електронні, змінні носії, транспортування, захист).
- Контроль доступу (встановлення правил, фізичні, логічні, MAC, DAC, RBAC, ABAC).
- Управління ідентифікацією (життєвий цикл ідентифікаторів, реєстрація, управління, вилучення).
- Інформація для автентифікації (належне поводження користувачів).
- Права доступу (надавати, переглядати, змінювати, політики, привілейовані).

ОРГАНІЗАЦІЙНИЙ КОНТРОЛЬ

- ІБ у відносинах з постачальниками (політика).
- ІБ в угодах з постачальниками.
- Управління ІБ в ланцюзі поставок ІКТ (постачальники постачальників).
- Моніторинг, аналіз та управління змінами послуг постачальника.
- ІБ використання хмарних сервісів.
- Планування та підготовка управління інцидентами ІБ (Подія ≠ Інцидент).
- Оцінка та прийняття рішень щодо подій ІБ (віднесення подій до інцидентів).
- Реагування на інциденти ІБ (процедури).
- Навчання з інцидентів ІБ.
- Збирання доказів.
- Безпека інформації під час збою.
- Готовність ІКТ до безперервності бізнесу.
- Правові, законодавчі, нормативні та договірні вимоги.
- Права інтелектуальної власності.
- Захист записів (організаційних, політик, планів, процедур, звітів).
- Конфіденційність і захист персональних даних (PII)
- Незалежна перевірка ІБ (через заплановані інтервали або значні зміни).
- Відповідність політикам і стандартам ІБ (регулярні перевірки).
- Задокументовані робочі процедури.

БЕЗПЕКА ЛЮДСЬКИХ РЕСУРСІВ
- Перевірка.
- Умови найму.
- Поінформованість, освіта й навчання щодо ІБ (тренінги, навчання).
- Дисциплінарний процес
(+ нагороди).
- Звільнення чи зміна посади.
- Угоди щодо конфіденційності або нерозголошення.
- Віддалена робота (місця віддаленої роботи, процедури).
- Звітування про події ІБ (звітування персоналу про події).

ФІЗИЧНИЙ КОНТРОЛЬ

- Периметр фізичної безпеки.
- Фізичний вхід (двері, ворота).
- Убезпечення офісів, кімнат та обладнання.
- Моніторинг фізичної безпеки (сигналізація, відеоспостереження).
- Захист від фізичних і екологічних загроз (стихія, пил).
- Робота в зонах безпеки (спеціальні засоби захисту).
- Політика чистого стола та чистого екрана.
- Розміщення та захист обладнання.
- Безпека активів (ресурсів) поза службовими приміщеннями (заходи захисту, правила виносу).
- Носії інформації (керування життєвим циклом, змінні)
- Допоміжні комунальні служби (законодавство, договори, резервування).
- Безпека кабельних мереж.
- Обслуговування обладнання (ТО, персонал, інтервали)
- Безпечне вилучення або повторне використання обладнання (видалення інформації).

ТЕХНОЛОГІЧНИЙ КОНТРОЛЬ

- Кінцеві пристрої користувачів (політика використання, обізнаність, BYOD (принесіть свій власний пристрій).
- Привілейовані права доступу.
- Обмеження доступу до інформації (проти НСД)
- Доступ до вихідного коду.
- Безпечна аутентифікація.
- Управління потужністю (продуктивність, ресурси).
- Захист від шкідливих програм.
- Управління технічною вразливістю (отримати інформацію про неї та усунути).
- Управління конфігурацією (АЗ/ПЗ, мереж, безпеки).
- Видалення інформації (коли непотрібно).
- Маскування даних.
- Запобігання витоку даних.
- Резервне копіювання інформації (політика, повне/часткове, частота, місце зберігання).
- Резервування засобів обробки інформації.
- Журналювання (політика, збереження, захист, аналіз).
- Моніторинг (аномалії, інциденти).
- Синхронізація годинників.
- Використання привілейованих службових програм (файлові менеджери, очищення дисків…)

ТЕХНОЛОГІЧНИЙ КОНТРОЛЬ

- Установка ПЗ на ОС (Захист ОС від неконтрольованого встановлення ПЗ).
- Безпека мереж (конфігурація, захист даних, що передається, бездротові).
- Безпека мережевих сервісів (від постачальників).
- Сегментація в мережах.
- Вебфільтрація (обізнаність користувачів, фільтрація).
- Використання криптографії (вимоги, керування ключами).
- Безпечний життєвий цикл розробки ПЗ.
- Вимоги до безпеки ПЗ (розроблених, придбаних).
- Архітектура безпечної системи та принципи її розробки.
- Безпечне програмування.
- Тестування безпеки під час розробки та приймальне тестування.
- Аутсорсингове розроблення.
- Розділення середовища розроблення, тестування та експлуатації.
- Управління змінами (процедури, контроль, планування, автоматизація, тестування, резервування).
- Тестова інформація (конфіденційні дані не можна використовувати в середовищах розробки та тестування).
- Захист інформаційних систем під час аудиту.

ISO 27003 Information technology - Security techniques –
Information security management systems implementation guidance
Інформаційні технології - Методи безпеки –
Інструкція з реалізації системи менеджменту інформаційної безпеки

Фази розробки проекту СМІБ:
Визначення пріоритетів організації для розробки СМІБ:
a) найважливіші сфери діяльності підприємства і організації;
b) засекречена або цінна інформація:
1. Найбільш важлива інформація для організації;
2. Наслідки при розголошенні;
c) закони, що регулюють заходи ІБ;
d) контрактні або організаційні угоди, які стосуються ІБ;
e) галузеві вимоги,
що визначають конкретні способи управління і заходи ІБ;
f) загрози;
g) конкурентні фактори;
h) вимоги безперервності бізнес-процесів.

Визначення попередньої сфери дії СМІБ:

a) обов'язкові вимоги до менеджменту ІБ,
що визначаються керівництвом і зобов’язаннями ззовні;

b) як система взаємодіє з іншими системами;

c) перелік цілей підприємства в області менеджменту ІБ;

d) перелік найважливіших бізнес-процесів, інформаційних активів,
організаційних структур і регіонів, де буде використовуватися СМІБ;

e) існуючи системи управління;

f) характеристики підприємства, організація,
місцезнаходження, активи і технології.

Розробка технічного обґрунтування та плану проекту:

a) цілі і конкретні завдання;

b) вигоди для організації;

c) область дії СМІБ та зачеплені бізнес-процеси;

d) найважливіші процеси і фактори для досягнення цілей СМІБ;

e) опис проекту високого рівня;

f) початковий план впровадження системи;

g) певні ролі і сфери відповідальності;

h) необхідні ресурси (технологічні та людські);

i) міркування, що стосуються впровадження системи;

j) тимчасова шкала з ключовими етапами;

k) передбачувані витрати;

l) найважливіші фактори успіху;

m) кількісне визначення вигод для організації.

Визначення області дії СМІБ, меж і політики СМІБ:

a) організаційну область дії і межи;

b) область дії і межи інформаційних і комунікаційних технологій (ІКТ);

- інфраструктура зв'язку;
- програмне забезпечення;
- апаратне забезпечення;
- ролі та сфери відповідальності;

c) фізичну область дії і межи.

Проведення аналізу вимог до ІБ.

Проведення оцінки ризику:

a) визначити загрози та їх джерела;

b) визначити існуючі та заплановані заходи і засоби контролю;

c) визначити уразливості,
які можуть в разі загрози завдати шкоди активів або організації;

d) визначити наслідки втрати конфіденційності, доступності,
безперервності або порушення інших вимог до безпеки для активів;

e) оцінити вплив на підприємство, який може виникнути в результаті
передбачуваних або фактичних інцидентів ІБ;

f) оцінити ймовірність надзвичайних сценаріїв;

g) оцінити рівень ризику;

h) порівняти рівні ризику
з критеріями оцінки та прийнятності ризиків.

Розробка СМІБ:

Організації:

- кінцевої структури організації для ІБ;
- політики ІБ;
- стандартів і процедур забезпечення ІБ;

ІКТ та фізичних об'єктів;

Плану проекту СМІБ.

Закон України Про захист інформації в інформаційно-телекомунікаційних системах

Основні визначення:

телекомунікаційна система - сукупність технічних і програмних засобів, призначених для обміну інформацією шляхом передавання, випромінювання або приймання її у вигляді сигналів, знаків, звуків, рухомих або нерухомих зображень чи в інший спосіб;
інформаційна (автоматизована) система - організаційно-технічна система, в якій реалізується технологія обробки інформації з використанням технічних і програмних засобів;
інформаційно-телекомунікаційна система - сукупність інформаційних та телекомунікаційних систем, які у процесі обробки інформації діють як єдине ціле;
комплексна система захисту інформації (КСЗІ) - взаємопов'язана сукупність організаційних та інженерно-технічних заходів, засобів і методів захисту інформації;

Основні визначення:

володілець інформації - фізична або юридична особа, якій належать права на інформацію;
власник системи - фізична або юридична особа, якій належить право власності на систему;
користувач інформації в системі (користувач) - фізична або юридична особа, яка в установленому законодавством порядку отримала право доступу до інформації в системі;
обробка інформації в системі - виконання однієї або кількох операцій, зокрема: збирання, введення, записування, перетворення, зчитування, зберігання, знищення, реєстрації, приймання, отримання, передавання, які здійснюються в системі за допомогою технічних і програмних засобів;
несанкціоновані дії щодо інформації в системі - дії, що провадяться з порушенням порядку доступу до цієї інформації, установленого відповідно до законодавства;

Основні визначення:

доступ до інформації в системі - отримання користувачем можливості обробляти інформацію в системі;
виток інформації - результат дій, внаслідок яких інформація в системі стає відомою чи доступною фізичним та/або юридичним особам, що не мають права доступу до неї;
блокування інформації в системі - дії, внаслідок яких унеможливлюється доступ до інформації в системі;
порушення цілісності інформації в системі - несанкціоновані дії щодо інформації в системі, внаслідок яких змінюється її вміст;
знищення інформації в системі - дії, внаслідок яких інформація в системі зникає;

Основні визначення:

порядок доступу до інформації в системі - умови отримання користувачем можливості обробляти інформацію в системі та правила обробки цієї інформації;
захист інформації в системі - діяльність, спрямована на запобігання несанкціонованим діям щодо інформації в системі;
технічний захист інформації (ТЗІ) - вид захисту інформації, спрямований на забезпечення за допомогою інженерно-технічних заходів та/або програмних і технічних засобів унеможливлення витоку, знищення та блокування інформації, порушення цілісності та режиму доступу до інформації.
криптографічний захист інформації (КЗІ) - вид захисту інформації, що реалізується шляхом перетворення інформації з використанням спеціальних (ключових) даних з метою приховування/відновлення змісту інформації, підтвердження її справжності, цілісності, авторства тощо.

Об'єктами захисту в системі є:
- інформація, що обробляється в ній,
- програмне забезпечення, яке призначено для обробки цієї інформації.

Суб'єктами відносин,
пов'язаних із **захистом інформації в системах**, є:
- володільці інформації;
- власники системи;
- користувачі;
- спеціально уповноважений центральний орган виконавчої влади з питань організації спеціального зв'язку та захисту інформації і підпорядковані йому регіональні органи;

ДССЗЗІ є спеціально уповноваженим центральним органом виконавчої влади з питань організації спеціального зв’язку та захисту інформації.

Порядок доступу:
- Комерційна, конфіденційна приватна інформація - визначається володільцем.
- Державна - визначається законодавством.

У випадках, передбачених законом, доступ до інформації в системі може здійснюватися без дозволу її володільця в порядку, встановленому законом.

Державна інформація повинна оброблятися в системі із застосуванням **КСЗІ**.
Підтвердження відповідності КСЗІ - за результатами **державної експертизи**.

Вимоги до забезпечення захисту державних інформаційних ресурсів встановлюються **Кабінетом Міністрів України**.

Спеціально уповноважений центральний орган виконавчої влади з питань організації спеціального зв'язку та захисту інформації (ДССЗЗІ):

- розробляє пропозиції щодо державної політики у сфері захисту інформації та забезпечує її реалізацію;
- визначає вимоги та порядок створення КСЗІ державних інформаційних ресурсів;
- організовує проведення державної експертизи КСЗІ;
- здійснює контроль за забезпеченням захисту державних інформаційних ресурсів;
- виявляє загрози державним інформаційним ресурсам та дає рекомендації з їх запобігання.

Захисту в системі підлягає:

- відкрита інформація, яка належить до державних інформаційних ресурсів;
- конфіденційна інформація, яка перебуває у володінні таких розпорядників інформації:
  - суб'єкти владних повноважень;
  - юридичні особи, що фінансуються з державного, місцевих бюджетів;
  - особи, що виконують владні повноваження;
  - суб'єкти, які займають домінуюче становище на ринку;
- службова інформація;
- таємна інформація;
- інформація, вимога щодо захисту якої встановлена законом.

Відкрита інформація:
- Забезпечення доступу;
- Захист від:
    - модифікації
    - знищення
    неавторизованими користувачами.

Службова і таємна інформації захист від:
- несанкціонованого ознайомлення,
- модифікації,
- знищення,
- копіювання,
- поширення.

У системі здійснюється **обов'язкова реєстрація**:
- результатів ідентифікації та автентифікації користувачів;
- результатів виконання користувачем операцій з обробки інформації;
- спроб несанкціонованих дій з інформацією;
- фактів надання та позбавлення користувачів права доступу до інформації та її обробки;
- результатів перевірки цілісності засобів захисту інформації.

Передача службової і таємної інформації з однієї системи до іншої здійснюється :
- у зашифрованому вигляді або
- захищеними каналами зв'язку.

Створюється **КСЗІ для захисту від**:
- витоку технічними каналами;
- несанкціонованих дій з інформацією;
- спеціального впливу на засоби обробки інформації, який може призвести до порушення її цілісності та несанкціонованого блокування.

Відповідальність за захист інформації покладається **на власника системи,** а саме:
- керівника (заступника керівника),
- керівників її структурних підрозділів, що забезпечують експлуатацію системи.

Організація та проведення робіт із захисту інформації в системі здійснюється **службою захисту інформації**.

Коли **обсяг робіт є незначний**, захист інформації може здійснюватися **однією особою**.

Виконавцем КСЗІ може бути суб'єкт,
який **має ліцензію або дозвіл** на роботи у сфері ТЗІ.

ДСТУ 3396.0-96
Захист інформації. Технічний захист інформації. Основні положення.

Об’єкт ТЗІ - інформація, що становить державну таємницю, конфіденційна інформація, що є державною власністю.

Носії ІзОД - фізичні поля, сигнали, хімічні речовини.

Середовище поширення носіїв ІзОД - лінії зв’язку, сигналізації, керування, енергетичні мережі, прикінцеве і проміжне обладнання, інженерні комунікації і споруди, відгороджувальні будівельні конструкції, а також світлопроникні елементи будинків і споруд (отвори), повітряне, водне та інші середовища, грунт, рослинність тощо.

Витік або порушення цілісності ІзОД (спотворення, модифікація, руйнування, знищення) можуть бути результатом реалізації загроз безпеці інформації.

Мета ТЗІ - запобігання витоку або порушенню цілісності ІзОД.

Загрози можуть здійснюватися:
- технічними каналами, що включають канали побічних електромагнітних випромінювань і наводок, акустичні, оптичні, радіо-, радіотехнічні, хімічні та інші канали;
- каналами спеціального впливу шляхом формування полів і сигналів з метою руйнування системи захисту або порушення цілісності інформації;
- несанкційованим доступом шляхом підключення до апаратури та ліній зв’язку, маскування під зареєстрованого користувача, подолання заходів захисту для використання інформації або нав’язування хибної інформації, застосування закладних пристроїв чи програм та вкорінення комп’ютерних вірусів.

ТЗІ забезпечується застосуванням захищених програм і технічних засобів забезпечення інформаційної діяльності, програмних і технічних засобів захисту інформації (засоби ТЗІ)

ДСТУ 3396.1-96
Захист інформації. Технічний захист інформації. Порядок проведення робіт.

Варіанти захисту інформації:
- досягнення необхідного рівня захисту ІзОД за мінімальних затрат і допустимого рівня обмежень видів ІД;
- досягнення необхідного рівня захисту ІзОД за допустимих затрат і заданого рівня обмежень видів ІД;
- досягнення максимального рівня захисту ІзОД за необхідних затрат і мінімального рівня обмежень видів ІД.

Зміст робіт з протидії загрозам полягає в:
- проведенні обстеження підприємства (складається акт);
- розробленні і реалізації організаційних і технічних заходів з використанням засобів забезпечення ТЗІ;
- прийманні робіт з ТЗІ;
- атестації засобів (систем) забезпечення ІД на відповідність вимогам нормативних документів з ТЗІ.

ДСТУ 3396.2-97
Захист інформації. Технічний захист інформації. Терміни та визначення.

Інформація,
інформація з обмеженим доступом,
таємна інформація,
конфіденційна інформація,
витік,
порушення цілісності,
блокування,
загроза,
модель загроз,
доступ,
несанкціонований доступ,
закладний пристрій,
програмна закладка,
вірус,
спеціальний вплив,
технічна розвідка,
носій інформації,
інформативний сигнал,
канал витоку,
побічне електромагнітне випромінення і навід,
засіб ТЗІ,
приховування інформації,
дезінформування,
система ТЗІ,
зона безпеки,
рівень ТЗІ,
ефективність ТЗІ.

НД ТЗІ 1.1-003-99 Термінологія в галузі захисту інформації в комп’ютерних системах від несанкціонованого доступу:

Обчислювальна система; ОС (computer system) - сукупність програмних-апаратних засобів, призначених для обробки інформації.

Автоматизована система; АС (automated system) - організаційно-технічна система, що реалізує інформаційну технологію і об’єднує ОС, фізичне середовище, персонал і інформацію, яка обробляється.

Комп’ютерна система; КС (computer system, target of evaluation) - сукупність програмно-апаратних засобів, яка подана для оцінки.

Політика безпеки інформації (information security policy) - сукупність законів, правил, обмежень, рекомендацій, інструкцій тощо, які регламентують порядок обробки інформації.

Загроза (threat) - будь-які обставини або події, що можуть бути причиною порушення політики безпеки інформації і/або нанесення збитків АС.

Термінологія в галузі ЗІ:

Безпека інформації (information security) - стан інформації, в якому забезпечується збереження визначених політикою безпеки властивостей інформації.
Захист інформації (ЗІ) в АС (information protection, information security, computer system security) - діяльність, яка спрямована на забезпечення безпеки оброблюваної в АС інформації та АС в цілому, і дозволяє запобігти або ускладнити можливість реалізації загроз, а також знизити величину потенційних збитків внаслідок реалізації загроз.
Комплексна система захисту інформації (КСЗІ) - сукупність організаційних і інженерних заходів, програмно-апаратних засобів, які забезпечують ЗІ в АС.
Користувач (user) - фізична особа, яка може взаємодіяти з КС через наданий їй інтерфейс.
Адміністратор безпеки (security administrator) - адміністратор, відповідальний за дотримання політики безпеки.

Термінологія в галузі ЗІ:

Порушник (user violator) - користувач, який здійснює НСД до інформації.
Ознайомлення (disclosure) - одержання користувачем або процесом інформації, що міститься в об’єкті.
Модифікація (modification) - зміна користувачем або процесом інформації, що міститься в об’єкті.
Конфіденційність інформації (information confidentiality) - властивість інформації, яка полягає в тому, що інформація не може бути отримана неавторизованим користувачем і/або процесом.
Цілісність інформації (information integrity) - властивість інформації, яка полягає в тому, що інформація не може бути модифікована неавторизованим користувачем і/або процесом.

Термінологія в галузі ЗІ:

Доступність (availability) - властивість ресурсу системи (КС, послуги, об’єкта КС, інформації), яка полягає в тому, що користувач і/або процес, який володіє відповідними повноваженнями, може використовувати ресурс відповідно до правил, встановлених політикою безпеки, не очікуючи довше заданого (малого) проміжку часу, тобто коли він знаходиться у вигляді, необхідному користувачеві, в місці, необхідному користувачеві, і в той час, коли він йому необхідний.

Атака (attack) - спроба реалізації загрози.

Проникнення (penetration) - успішне подолання механізмів захисту системи.

Вразливість системи (system vulnerability) - нездатність системи протистояти реалізації певної загрози або сукупності загроз.

Компрометація (compromise) - порушення політики безпеки; несанкціоноване ознайомлення.

Термінологія в галузі ЗІ:

Люк (trap door) - залишені розробником недокументовані функції, використання яких дозволяє обминути механізми захисту.

Троянський кінь (Trojan horse) - програма, яка, будучи авторизованим процесом, окрім виконання документованих функцій, здатна здійснювати приховані дії від особи авторизованого користувача в інтересах розробника цієї програми.

Збирання сміття - загроза, що полягає в захопленні і аналізі користувачем або процесом спільно використовуваних об’єктів, звільнених іншим користувачем чи процесом, з метою одержання інформації, що в них знаходиться.

Модель загроз (model of threats) - абстрактний формалізований або неформалізований опис методів і засобів здійснення загроз.

Модель порушника (user violator model) - абстрактний формалізований або неформалізований опис порушника.

Термінологія в галузі ЗІ:

Ризик (risk) - функція ймовірності реалізації певної загрози, виду і величини завданих збитків.
Керування ризиком (risk management) - сукупність заходів, що проводяться протягом всього життєвого циклу АС щодо оцінки ризику, вибору, реалізації і впровадження заходів забезпечення безпеки, спрямована на досягнення прийнятного рівня залишкового ризику.
Тестування на проникання (penetration testing) - випробування, метою яких є здійснення спроби обминути або відключити механізми захисту.
Оцінка вразливості (vulnerability assessment) - дослідження об’єкта оцінки з метою визначення можливості реалізації загроз.
Ідентифікація (identification) - впізнання.
Автентифікація (authentication) - встановлення або підтвердження автентичності.

Термінологія в галузі ЗІ:

Пароль (password) - секретна інформація автентифікації, що являє собою послідовність символів, яку користувач повинен ввести через обладнання вводу інформації, перш ніж йому буде надано доступ до КС або до інформації.
Журнал реєстрації (audit trail) - упорядкована сукупність реєстраційних записів, кожен з яких заноситься за фактом здійснення контрольованої події.
Відкат (rollback) - послуга, що забезпечує повернення об’єкта КС до відомого попереднього стану після виконання над об’єктом певної операції або серії операцій.
Список повноважень (privilege list, profile) - перелік об’єктів з зазначенням прав доступу до них з боку користувача або процесу, з яким пов’язаний цей перелік.

Термінологія в галузі ЗІ:

Криптографічне перетворення - перетворення даних, яке полягає в їх шифруванні, вироблення імітовставки або цифрового підпису.
Зашифрування даних (data encryption) - процес перетворення відкритого тексту в шифртекст.
Відкритий текст (clear text) - дані з доступним семантичним змістом.
Шифртекст (ciphertext) - дані, отримані у результаті зашифрування відкритого тексту.
Імітовставка (data authentication code) - блок інформації фіксованої довжини, що одержується із відкритого тексту і ключа, однозначно відповідний даному відкритому тексту.
Цифровий підпис (digital signature) - дані, одержані в результаті криптографічного перетворення блоку даних і/або його параметрів (хеш-функції, довжини, дати утворення, ідентифікатора відправника і т. ін.), що дозволяють приймальнику даних впевнитись в цілісності блоку і справжності джерела даних і забезпечити захист від підробки і підлогу.

Термінологія в галузі ЗІ:

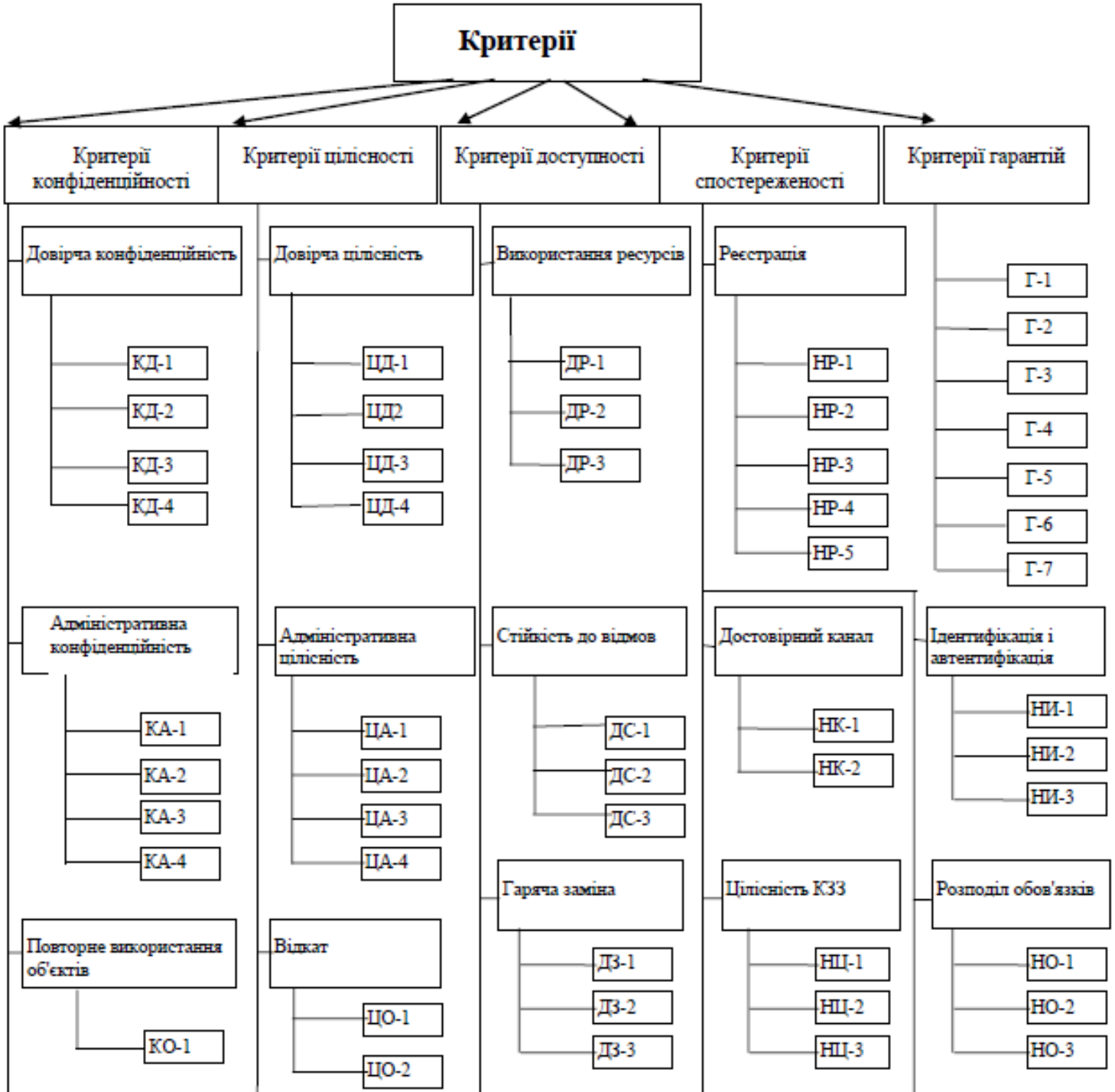
Обчислювальна система; ОС (computer system) - сукупність програмних-апаратних засобів, призначених для обробки інформації.

Автоматизована система; АС (automated system) - організаційно-технічна система, що реалізує інформаційну технологію і об’єднує ОС, фізичне середовище, персонал і інформацію, яка обробляється.

Комп’ютерна система; КС (computer system, target of evaluation) - сукупність програмно-апаратних засобів, яка подана для оцінки.

Політика безпеки інформації (information security policy) - сукупність законів, правил, обмежень, рекомендацій, інструкцій тощо, які регламентують порядок обробки інформації.

Загроза (threat) - будь-які обставини або події, що можуть бути причиною порушення політики безпеки інформації і/або нанесення збитків АС.



Критерії оцінки захищеності інформації в комп’ютерних системах від НСД (НД ТЗІ 2.5-004-99)

- функціональні,
- гарантії.

<table>
<tr><th>КД-1. Мінімальна довірча конфіденційність</th><th>КД-2. Базова довірча конфіденційність</th><th>КД-3. Повна довірча конфіденційність</th><th>КД-4. Абсолютна довірча конфіденційність</th></tr>
<tr><td colspan="2">Політика довірчої конфіденційності, що реалізується КЗЗ, повинна визначати множину об'єктів КС, до яких вона відноситься</td><td colspan="2">Політика довірчої конфіденційності, що реалізується КЗЗ, повинна відноситись до всіх об'єктів КС</td></tr>
<tr><td colspan="4">КЗЗ повинен здійснювати розмежування доступу на підставі атрибутів доступу</td></tr>
<tr><td>процесу і захищеного об'єкта</td><td colspan="2">користувача і захищеного об'єкта</td><td>користувача, процесу і захищеного об'єкта</td></tr>
<tr><td colspan="4">Запити на зміну прав доступу до об'єкта повинні оброблятися КЗЗ на підставі атрибутів доступу користувача, що ініціює запит, і об'єкта</td></tr>
<tr><td colspan="4">КЗЗ повинен надавати користувачу можливість для кожного захищеного об'єкта, що належить його домену, визначити</td></tr>
<tr><td>конкретні процеси і/або групи процесів, які мають право одержувати інформацію від об'єкта</td><td>конкретних користувачів і/або групи користувачів, які мають право одержувати інформацію від об'єкта</td><td>конкретних користувачів (і групи користувачів), які мають, а також тих, які не мають права одержувати інформацію від об'єкта</td><td>конкретних користувачів і процеси (і групи користувачів і процесів), які мають, а також тих, які не мають права одержувати інформацію від об'єкта</td></tr>
<tr><td rowspan="2">—</td><td colspan="3">КЗЗ повинен надавати користувачу можливість для кожного процесу, що належить його домену, визначити</td></tr>
<tr><td>конкретних користувачів і/або групи користувачів, які мають право ініціювати процес</td><td colspan="2">конкретних користувачів (і групи користувачів), які мають, а також тих, що не мають права ініціювати процес</td></tr>
<tr><td colspan="4">Права доступу до кожного захищеного об'єкта повинні встановлюватись в момент його створення або ініціалізації. Як частина політики довірчої конфіденційності повинні бути представлені правила збереження атрибутів доступу об'єктів під час їх експорту та імпорту</td></tr>
<tr><td colspan="2">НЕОБХІДНІ УМОВИ: НИ-1</td><td colspan="2">НЕОБХІДНІ УМОВИ: КО-1, НИ-1</td></tr>
</table>

КО-1. Повторне використання об'єктів
Політика повторного використання об'єктів, що реалізується КЗЗ, повинна відноситись до всіх об'єктів КС Перш ніж користувач або процес зможе одержати в своє розпорядження звільнений іншим користувачем або процесом об'єкт, встановлені для попереднього користувача або процесу права доступу до даного об'єкта повинні бути скасовані Перш ніж користувач або процес зможе одержати в своє розпорядження звільнений іншим користувачем або процесом об'єкт, вся інформація, що міститься в даному об'єкті, повинна стати недосяжною
НЕОБХІДНІ УМОВИ: НЕМАЄ

КК-1. Виявлення прихованих каналів	**КК-2. Контроль прихованих каналів**	**КК-3. Перекриття прихованих каналів**
Повинен бути виконаний аналіз прихованих каналів		
Всі приховані канали, які існують в апаратному і програмному забезпеченні, а також в програмах ПЗП, повинні бути документовані Має бути документована максимальна пропускна здатність кожного знайденого прихованого каналу, одержана на підставі теоретичної оцінки або вимірів Для прихованих каналів, які можуть використовуватися спільно, повинна бути документована сукупна пропускна здатність		Всі (затверджена підмножина) знайдені під час аналізу приховані канали повинні бути усунені
—	КЗЗ повинен забезпечувати реєстрацію використання затвердженої підмножини знайдених прихованих каналів	
НЕОБХІДНІ УМОВИ: КО-1, Г-3	НЕОБХІДНІ УМОВИ: КО-1, НР-1, Г-3	НЕОБХІДНІ УМОВИ: КО-1, Г-3

ЦО-1. Обмежений відкат	**ЦО-2. Повний відкат**
Політика відкату, що реалізується КЗЗ, повинна визначати множину об'єктів КС, до яких вона відноситься	
Повинні існувати автоматизовані засоби, які дозволяють авторизованому користувачу або процесу відкатити або відмінити	
певний набір (множину) операцій, виконаних над захищеним об'єктом за певний проміжок часу	всі операції, виконані над захищеним об'єктом за певний проміжок часу

<table>
<tr><th>ДС-1. Стійкість при обмежених відмовах</th><th>ДС-2. Стійкість з погіршенням характеристик обслуговування</th><th>ДС-3. Стійкість без погіршення характеристик обслуговування</th></tr>
<tr><td colspan="3">Розробник повинен провести аналіз відмов компонентів КС</td></tr>
<tr><td>Політика стійкості до відмов, що реалізується КЗЗ, повинна визначати множину компонентів КС, до яких вона відноситься, і типи їх відмов, після яких КС в змозі продовжувати функціонування</td><td colspan="2">Політика стійкості до відмов, що реалізується КЗЗ, повинна відноситися до всіх компонентів КС</td></tr>
<tr><td colspan="3">Повинні бути чітко вказані рівні відмов, при перевищенні яких відмови призводять до зниження характеристик обслуговування або недоступності послуги</td></tr>
<tr><td colspan="2">Відмова одного захищеного компонента не повинна призводити до недоступності всіх послуг, а має в гіршому випадку проявлятися в зниженні характеристик обслуговування</td><td>Відмова одного захищеного компонента не повинна призводити до недоступності всіх послуг або до зниження характеристик обслуговування</td></tr>
<tr><td colspan="3">КЗЗ повинен бути спроможний повідомити адміністратора про відмову будь-якого захищеного компонента</td></tr>
<tr><td colspan="3">НЕОБХІДНІ УМОВИ: НО-1</td></tr>
</table>

Вимоги	Г-1	Г-2	Г-3	Г-4	Г-5	Г-6	Г-7
КЗЗ повинен реалізовувати політику безпеки. Всі його компоненти повинні бути чітко визначені	+	=	=	=	=	=	=
КЗЗ повинен складатися з добре визначених і максимально незалежних компонентів. Кожний з компонентів повинен бути спроектований відповідно до принципу мінімуму повноважень	-	-	+	=	=	=	=
Критичні для безпеки компоненти КЗЗ повинні бути захищені від не критичних для безпеки за рахунок використання механізмів захисту, які надаються програмно-апаратними засобами більш низького рівня	-	-	-	+	=	=	=
З боку Розробника мають бути вжиті зусилля, спрямовані на виключення з КЗЗ компонентів, що не є критичними для безпеки. Мають бути наведені підстави для включення до КЗЗ будь-якого елемента, який не має відношення до захисту	-	-	-	-	+	=	=
Розробка ПЗ переважно має бути спрямована на мінімізацію складності КЗЗ. КЗЗ має бути спроектований і структурований так, щоб використовувати повний і концептуально простий механізм захисту з точно визначеною семантикою. Цей механізм повинен відігравати центральну роль в реалізації внутрішньої структури КЗЗ. Під час розробки КЗЗ значною мірою повинні бути задіяні такі підходи як модульність побудови і приховання (локалізація) даних	-	-	-	-	+	=	=

Г1-Г7 це вимоги до:
- архітектури,
- середовища розробки,
- процесу проектування,
- середовища функціонування.

Класифікація інформації:

- відкрита:
    - не потребує захисту;
    - потребує захисту;
- з обмеженим доступом:
    - конфіденційна;
    - таємна:
        - державна таємниця:
            - таємна;
            - цілком таємна;
            - особливої важливості;
        - інша передбачена законом таємниця.

Компоненти АС та технології обробки інформації:
- обладнання - ЕОМ та їхні складові частини (процесори, монітори, термінали, робочі станції та ін.), периферійні пристрої;
- програмне забезпечення - вихідні, завантажувальні модулі, утиліти, СКБД, операційні системи та інші системні програми, діагностичні і тестові програми тощо;
- дані - тимчасового і постійного зберігання, на магнітних носіях, друковані, архівні і резервні копії, системні журнали, технічна, експлуатаційна і розпорядча документація та ін.;
- персонал і користувачі АС.

Способи здійснення загроз в АС:

- технічними каналами, (побічних електромагнітних випромінювань і наводок, акустичні, оптичні, радіо- та радіотехнічні, хімічні);
- каналами спеціального впливу шляхом формування полів і сигналів з метою руйнування системи захисту або порушення цілісності інформації;
- НСД шляхом підключення до апаратури та ліній зв’язку, маскування під зареєстрованого користувача, подолання заходів захисту з метою використання інформації або нав’язування хибної інформації, застосування закладних пристроїв чи програм та вкорінення комп’ютерних вірусів.

Загрози:
- об'єктивну природа;
- суб'єктивну природа:
    - випадкові (ненавмисні);
    - навмисні.

Приклад основних видів загроз:
- зміна умов фізичного середовища (стихійні лиха і аварії, як землетрус, повінь, пожежа або інші випадкові події);
- збої і відмови у роботі обладнання та технічних засобів АС;
- наслідки помилок під час проектування та розробки компонентів АС (технічних засобів, технології обробки інформації, ПЗ, засобів захисту, структур даних);
- помилки персоналу (користувачів) АС під час експлуатації; навмисні дії (спроби) потенційних порушників.

Випадкові загрозами суб’єктивної природи (дії персоналу або користувачів по неуважності, недбалості, незнанню тощо, без навмисного наміру):

- дії, що призводять до відмови АС, руйнування апаратних, програмних, інформаційних ресурсів;
- ненавмисне пошкодження носіїв інформації;
- неправомірна зміна режимів роботи АС, які здатні призвести до незворотних змін у системі (форматування носіїв інформації);
- неумисне зараження вірусами;
- невиконання вимог захисту;
- помилки під час введення даних в систему;
- розголошення конфіденційних відомостей, атрибутів розмежування доступу, втрата атрибутів;
- впровадження і використання забороненого політикою безпеки ПЗ (ігрові програми);
- некомпетентне застосування засобів захисту.

Навмисні загрози суб’єктивної природи:

- порушення фізичної цілісності АС;
- порушення режимів функціонування (виведення з ладу) систем життєзабезпечення АС (електроживлення, заземлення, охоронної сигналізації, вентиляції та ін.);
- порушення режимів функціонування АС (обладнання і ПЗ);
- впровадження і використання комп’ютерних вірусів, закладних (апаратних і програмних) і підслуховуючих пристроїв, інших засобів розвідки;
- використання засобів перехоплення побічних електромагнітних випромінювань і наводок, акусто-електричних перетворень інформаційних сигналів;
- використання (шантаж, підкуп) персоналу АС;
- крадіжки носіїв інформації, виробничих відходів (роздруків, записів);
- несанкціоноване копіювання носіїв інформації;
- одержання атрибутів доступу з наступним їх використанням для маскування під зареєстрованого користувача («маскарад»);
- неправомірне підключення до каналів зв’язку, перехоплення даних, що передаються, аналіз трафіку;
- впровадження і використання забороненого політикою безпеки ПЗ, щоб одержати доступ до критичної інформації (аналізаторів безпеки мереж).

Модель порушника - опис дій порушника, який відображає його практичні та теоретичні можливості, знання, час та місце дії і т.ін.

Модель порушника повинна визначати:
- мету порушника та її градацію за ступенями небезпечності;
- категорії осіб, з числа яких може бути порушник;
- припущення про кваліфікацію порушника;
- припущення про характер його дій.

Класифікація порушників:

- за рівнем можливостей, (кожний наступний рівень включає в себе можливості попереднього):

1. Запуск фіксованого набору програм, що реалізують заздалегідь передбачені функції обробки інформації;
2. Створення і запуску власних програм з новими функціями обробки інформації;
3. Управління функціонуванням АС;
4. Повний обсяг можливостей до включення власних засобів з новими функціями обробки інформації.

- за рівнем знань:

- володіють інформацією про функціональні особливості АС, основні закономірності формування в ній масивів даних та потоків запитів до них, вміють користуватися штатними засобами;
- володіють високим рівнем знань та досвідом роботи з технічними засобами системи та їх обслуговування;
- володіють високим рівнем знань у галузі обчислювальної техніки та програмування, проектування та експлуатації АС;
- володіють інформацією про функції та механізм дії засобів захисту.

Класифікація порушників:

- за використовуваними методами:

- виключно агентурні методи;
- пасивні технічні засоби перехоплення інформаційних сигналів;
- виключно штатні засоби АС або недоліки проектування КСЗІ для реалізації спроб НСД;
- способи і засоби активного впливу на АС, що змінюють конфігурацію системи (підключення додаткових або модифікація штатних технічних засобів, підключення до каналів передачі даних, впровадження і використання спеціального ПЗ тощо).

- за місцем дії:

- без доступу на контрольовану територію;
- з доступом на контрольовану територію, але без доступу до технічних засобів АС;
- з доступом до робочих місць користувачів АС;
- з доступом до місць накопичення і зберігання даних (баз даних, архівів);
- з доступом до засобів адміністрування АС і засобів керування КСЗІ.

Методологія розробки політики безпеки включає:

- розробка концепції безпеки інформації в АС;
- аналіз ризиків:
    - ідентифікація загроз;
    - оцінка ризиків;
    - оцінювання величини можливих збитків;
- визначення вимог до заходів, методів та засобів захисту;
- вибір основних рішень з забезпечення безпеки інформації:
    - правові;
    - організаційні;
    - технічні;
- організація виконання відновлювальних робіт і забезпечення неперервного функціонування АС;
- документальне оформлення політики безпеки.

Правові:

- системи нормативно-правового забезпечення ЗІ;
- виконання правових та договірних вимог з ЗІ, визначення відповідальності осіб, оргструктури і розподілу обов'язків співробітників СЗІ;
- доведення до персоналу політики безпеки, їх навчання з питань ЗІ;
- контроль за своєчасністю, ефективністю і повнотою реалізації рішень з ЗІ, дотриманням персоналом положень політики безпеки.

Організаційні:

- режимні заходи на об’єктах АС;
- фізичний захист обладнання, носіїв інформації, ресурсів;
- обстеження середовищ функціонування АС;
- взаємодія з питань ЗІ з іншими суб’єктами ТЗІ;
- модернізація АС;
- регламентації доступу сторонніх користувачів до ресурсів АС;
- регламентації доступу власних користувачів до ресурсів АС;
- профілактичні заходи (попередження ненавмисних дій, появи вірусів);
- реалізації найбільш критичних положень політики безпеки (віддалений доступ, використання мережі Internet, несертифікованого ПЗ).

Технічні:

- інженерно-технічне обладнання приміщень, в яких розміщуються компоненти АС, блокування технічних каналів витоку інформації;
- реєстрація користувачів АС, авторизація користувачів в системі;
- керування доступом до інформації, розподілу ролей; виявлення і реєстрація небезпечних подій;
- забезпечення цілісності критичних даних;
- забезпечення конфіденційності інформації, (криптографічні засоби);
- резервне копіювання критичних даних, архівів ПЗ;
- відновлення роботи АС після збоїв, відмов;
- захист ПЗ від несанкціонованих доповнень і змін;
- функціонування засобів контролю (виявлення технічних каналів витоку інформації).

Під час обстеження проводять аналіз:
– умов функціонування ОІД, особливостей розташування його на місцевості, відносно меж контрольованої зони (КЗ), архітектурно-будівельних особливостей тощо;
– технічних засобів, що оброблятимуть ІзОД, та технічних засобів, які не використовують безпосередньо для її оброблення, визначають місця їх розташування на ОІД;
– розташування інженерних комунікацій та металоконструкцій, виявляють транзитні, незадіяні (повітряні, зовнішні, підземні) комунікації (для опрацювання пропозицій щодо їх вилучення чи доопрацювання), а також такі, що виходять за межі КЗ;
– необхідності впровадження інженерних і технічних заходів захисту від витоку ІзОД технічними каналами.

Категоріювання - сукупність дій зі встановлення категорії об'єкта;

Категоріювання може бути:
- первинним,
- черговим,
- позачерговим.

Об'єкти категоріювання – об'єкти інформаційної діяльності, в тому числі об'єкти ЕОТ.

IV категорія – об'єкти, на яких обробляється інформація з обмеженим доступом, що не становить державної таємниці.
III категорія – може встановлюватися за рішенням:
розпорядників (користувачів) інформації,
власників (розпорядників, користувачів) об'єктів, на яких обробляється інформація
з обмеженим доступом, що не становить державної таємниці.

Категоріювання об'єктів проводиться **комісією з категоріювання** установи власника (розпорядника, користувача) об'єкта.

Акт категоріювання об'єкта є чинним протягом **5 років.**